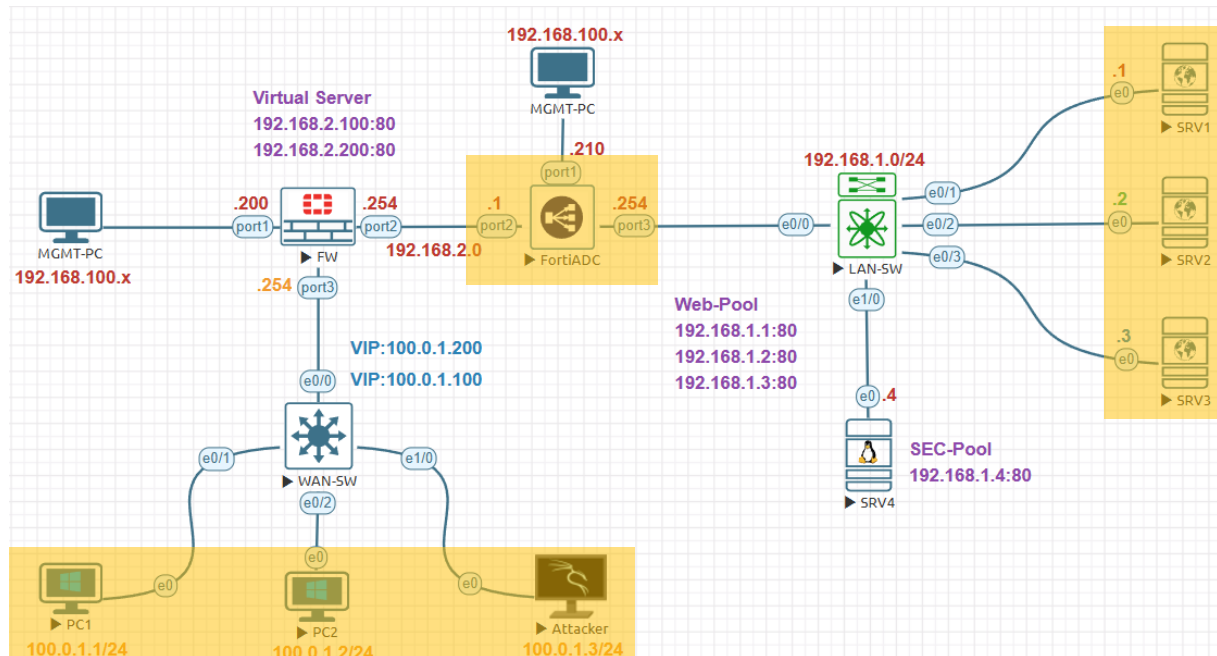


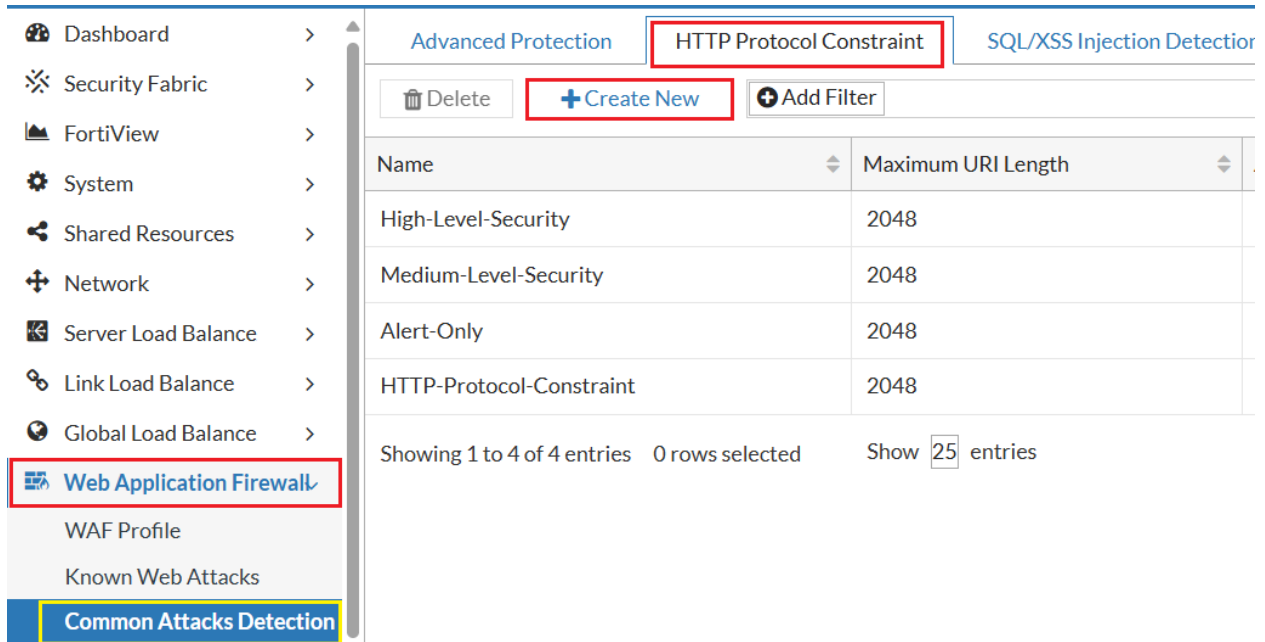
Web Application Firewall Lab:



Management Subnet	192.168.100.0/24
FortiGate Management IP	192.168.100.200
FortiADC Management IP	192.168.100.210
Internal Servers Subnet	192.168.1.0/24
FortiADC External Subnet	192.168.2.0/24
FortiGate Firewall External	100.0.1.0/24
FortiADC Internal IP Address	192.168.1.254
FortiADC External IP Address	192.168.2.1
FortiGate Firewall Internal IP	192.168.2.254
FortiGate Firewall External IP	100.0.1.254
SRV1 IP Address	192.168.1.1
SRV2 IP Address	192.168.1.2
SRV3 IP Address	192.168.1.3
SRV3 IP Address	192.168.1.4
Virtual Sever-1	192.168.2.100
Virtual Sever-2	192.168.2.200
FortiGate VIP-1	100.0.1.100
FortiGate VIP-2	100.0.1.200
External PC1 IP Address	100.0.1.1
External PC2 IP Address	100.0.1.2
External PC3 IP Address	100.0.1.3

Web Application Firewall Setting:

Before create Web Application Firewall Profile let's configure other configuration, Click **Web Application Firewall >Common Attacks Detection>HTTP Protocol Constraint**. Click the **Create New** to create new HTTP Protocol Constraint using following settings

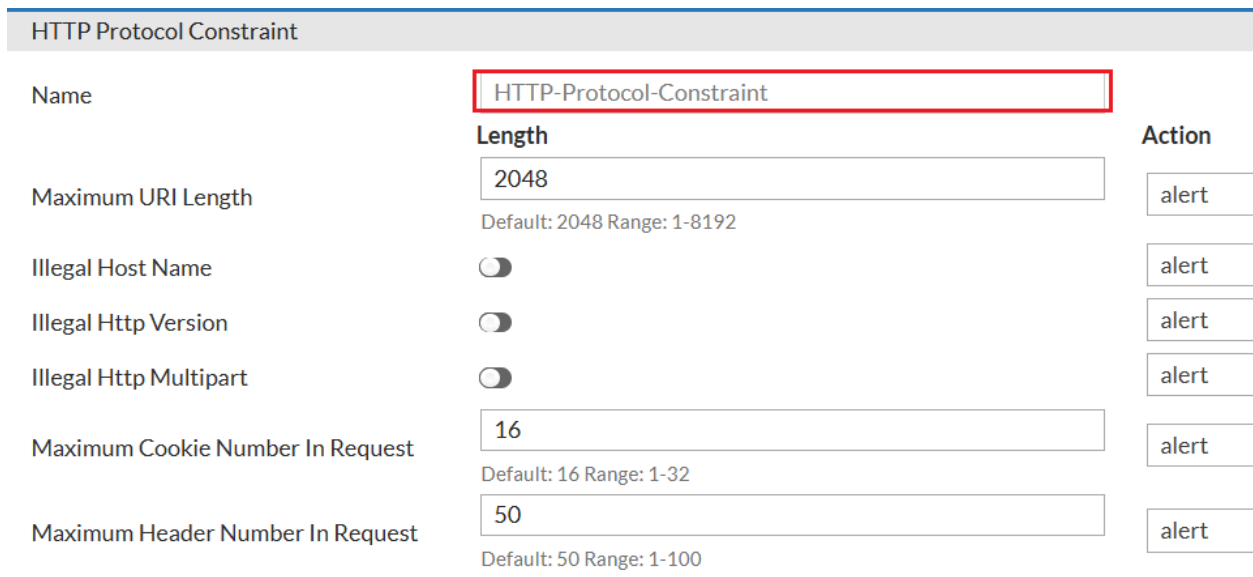


The screenshot shows the FortiGate Web Application Firewall configuration interface. The left sidebar contains a navigation menu with the following items: Dashboard, Security Fabric, FortiView, System, Shared Resources, Network, Server Load Balance, Link Load Balance, Global Load Balance, Web Application Firewall (highlighted), WAF Profile, Known Web Attacks, and Common Attacks Detection (highlighted). The main content area displays the 'HTTP Protocol Constraint' configuration page. At the top, there are three tabs: 'Advanced Protection', 'HTTP Protocol Constraint' (selected), and 'SQL/XSS Injection Detector'. Below the tabs, there are three buttons: 'Delete', '+ Create New' (highlighted), and '+ Add Filter'. A table lists the existing HTTP Protocol Constraints:

Name	Maximum URI Length
High-Level-Security	2048
Medium-Level-Security	2048
Alert-Only	2048
HTTP-Protocol-Constraint	2048

Below the table, it says 'Showing 1 to 4 of 4 entries 0 rows selected Show 25 entries'.

Give it a name in this case HTTP-Protocol-Constraint and click **Save**.



The screenshot shows the 'HTTP Protocol Constraint' configuration page. The 'Name' field is set to 'HTTP-Protocol-Constraint'. The 'Length' field is set to '2048'. The 'Maximum URI Length' field is set to '2048'. The 'Illegal Host Name', 'Illegal Http Version', and 'Illegal Http Multipart' fields are set to 'alert'. The 'Maximum Cookie Number In Request' field is set to '16'. The 'Maximum Header Number In Request' field is set to '50'.

Field	Value	Action
Name	HTTP-Protocol-Constraint	
Length	2048	
Maximum URI Length	2048	alert
Illegal Host Name	☐	alert
Illegal Http Version	☐	alert
Illegal Http Multipart	☐	alert
Maximum Cookie Number In Request	16	alert
Maximum Header Number In Request	50	alert

In the **Constraint Method Override** section click the **Create New** to create Request Method Rule

Constraint Method Override



Request Method Rule

Delete

Create New

Add Filter

ID	Method	Action	Severity	Exception Name
1	GET	deny	High	

Showing 1 to 1 of 1 entries

0 rows selected

Show

25

entries

Response Code Rule

	+ Create New	+ Add Filter
ID	Minimum Status Code	Maximum Status Code

Choose the Method: **GET** and click **Save**.

Request Method Rule

Method

☐ CONNECT ☐ DELETE ☒ GET ☐ HEAD ☐ OPTIONS ☐ POST ☐ PUT
☐ TRACE ☐ OTHERS

Action

deny

Severity

High Medium Low

Exception Name

Click to select

[Save](#) [Cancel](#)

Finally, HTTP Protocol Constraint is created.

Advanced Protection

HTTP Protocol Constraint

SQL/XSS Injection Detection

CSRF Protection

Delete

Create New

Add Filter

Name	Maximum URI Length	Action	Severity	Request
High-Level-Security	2048	deny	High	0
Medium-Level-Security	2048	alert	Medium	0
Alert-Only	2048	alert	Low	0
HTTP-Protocol-Constraint	2048	alert	Low	1

Showing 1 to 4 of 4 entries 0 rows selected

Show

25

entries

Next, Click **Web Application Firewall >Common Attacks Detection>SQL/XSS Injection Detection**. In this case we will use the Default one High-Level-Security.

Advanced Protection

HTTP Protocol Constraint

SQL/XSS Injection Detection

CSRF Protection

Delete

Create New

Add Filter

Name	SQL Injection Detection	SQL Action	SQL Exception	XSS Injection Detection
High-Level-Security	Enable	deny		Enable
Medium-Level-Security	Enable	deny		Disable
Alert-Only	Enable	alert		Disable

Showing 1 to 3 of 3 entries

0 rows selected

Show 25 entries

Next, Click **Web Application Firewall >Access Protection>URL Protection**. Click **Create New**

Global Load Balance >

Web Application Firewall

WAF Profile

Known Web Attacks

Common Attacks Detection

Sensitive Data Protection

Input Validation

Access Protection

URL Protection

Brute Force Attack Detection

Credential Stuffing Defense

Delete

Create New

Add Filter

Name	URL Access Rule Count
URL-Protection	1

Showing 1 to 1 of 1 entries0 rows selectedShow 25 entries

Give it a name in this case **URL-Protection** and click **Save** to enable **Create New**.

Global Load Balance >

Web Application Firewall

WAF Profile

Known Web Attacks

Common Attacks Detection

Sensitive Data Protection

Input Validation

Access Protection

CORS Protection

URL Protection

Name

URL-Protection

URL Access Rule

Delete

+ Create New

+ Add Filter

ID	Full URL Pattern	Action

Showing 1 to 1 of 1 entries

0 rows selected

Show 25 entries

In URL Access Rule

Full URL Pattern: **/twiki**,

Action: deny,

Severity: High

And finally click **Save**.

URL Protection

URL Access Rule

Name URL-Protection

Full URL Pattern » /twiki

Maximum length is 127 characters

Action deny

Severity High Medium Low

Exception Name Click to select

Save

Finally, our new URL Protection Profile has been created.

Global Load Balance >

Web Application Firewall

WAF Profile

Known Web Attacks

Common Attacks Detection

Sensitive Data Protection

Input Validation

Access Protection

URL Protection Brute Force Attack Detection Credential Stuffing Defense

Delete + Create New + Add Filter

Name	URL Access Rule Count
URL-Protection	1

Showing 1 to 1 of 1 entries 0 rows selected Show 25 entries

Web Application Firewall Profile:

Now let's create WAF Profile, Click **Web Application Firewall > WAF Profile**. Click the **Create New** to create new WAF Profile using following settings.

Name	Action	Exceptions
High-Level-Security	High-Level-Security	High-Level-Security
Medium-Level-Security	Medium-Level-Security	Medium-Level-Security
Alert-Only	Alert-Only	Alert-Only

Showing 1 to 4 of 4 entries 0 rows selected Show 25 entries

Give it a name in this case WAF-Profile,

HTTP Protocol Constraint: HTTP-Protocol-Constraint

WAF Profile

Name: WAF-Profile

Exception Name: Click to select

Description: Optional description.

Rule Match Record: Off

Standard Protection

Web Attack Signature: High-Level-Security

HTTP Protocol Constraint: HTTP-Protocol-Constraint

Sensitive Data Protection

Cookie Security: Click to select

SQL/XSS Injection Detection: High-Level-Security and click **Save**.

Shared Resources >

Network >

Server Load Balance >

Link Load Balance >

Global Load Balance >

Web Application Firewall

WAF Profile

Input Protection

SQL/XSS Injection Detection High-Level-Security

Input Validation Policy Click to select

CORS Protection Click to select

Access Protection

Brute Force Attack Detection BruteForce

Finally, our new WAF profile is ready with the name WAF-Profile.

WAF Profile

Action

Exceptions

Delete

Create New

Add Filter

Name	Web Attack Signature	HTTP Protocol Constraint
High-Level-Security	High-Level-Security	High-Level-Security
Medium-Level-Security	Medium-Level-Security	Medium-Level-Security
Alert-Only	Alert-Only	Alert-Only
WAF-Profile	High-Level-Security	HTTP-Protocol-Constraint

Attach WAF Profile to VS:

Click **Server Load Balance > Virtual Server > Virtual Server**. Click the edit icon or double click to edit the new virtual server **SEC-VS**.

The screenshot shows the FortiGate Web UI. On the left sidebar, 'Server Load Balance' is selected. The main panel shows the 'Virtual Server' tab. A table lists the virtual servers:

Name	Type	Address	Port
WEB-VS	Layer 4	192.168.2.100	80
SEC-VS	Layer 7	192.168.2.200	80
HTTPS-VS	Layer 7	192.168.2.100	443

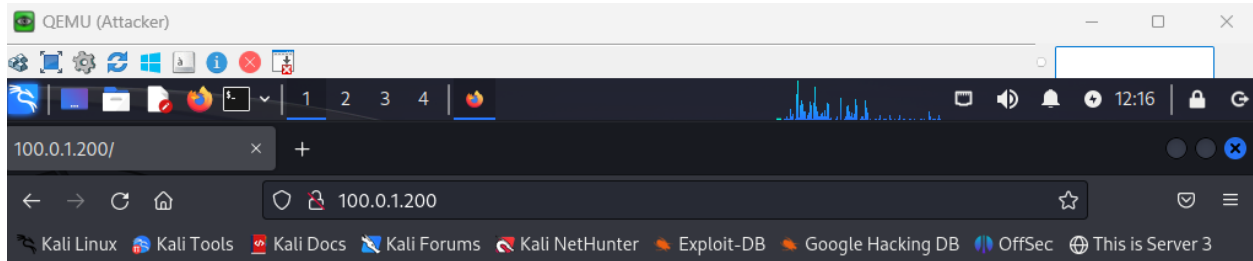
On the **Security** tab, change the **WAF Profile** setting to **WAF-Profile**, and then click **Save**.

The screenshot shows the FortiGate Web UI with the 'Security' tab selected for the 'Virtual Server'. The 'WAF Profile' is set to 'WAF-Profile'.

Setting	Value
WAF Profile	WAF-Profile
AV Profile	AV-Profile
DoS Protection Profile	Click to select
Captcha Profile	LB_CAPTCHA_PROFILE_DEFAULT

Testing & Verification:

On the External Kali Linux, open Firefox browser and type <http://100.0.1.200> the Access is Denied due to HTTP Protocol Constraint rule inside WAF-Profile.



Access Denied

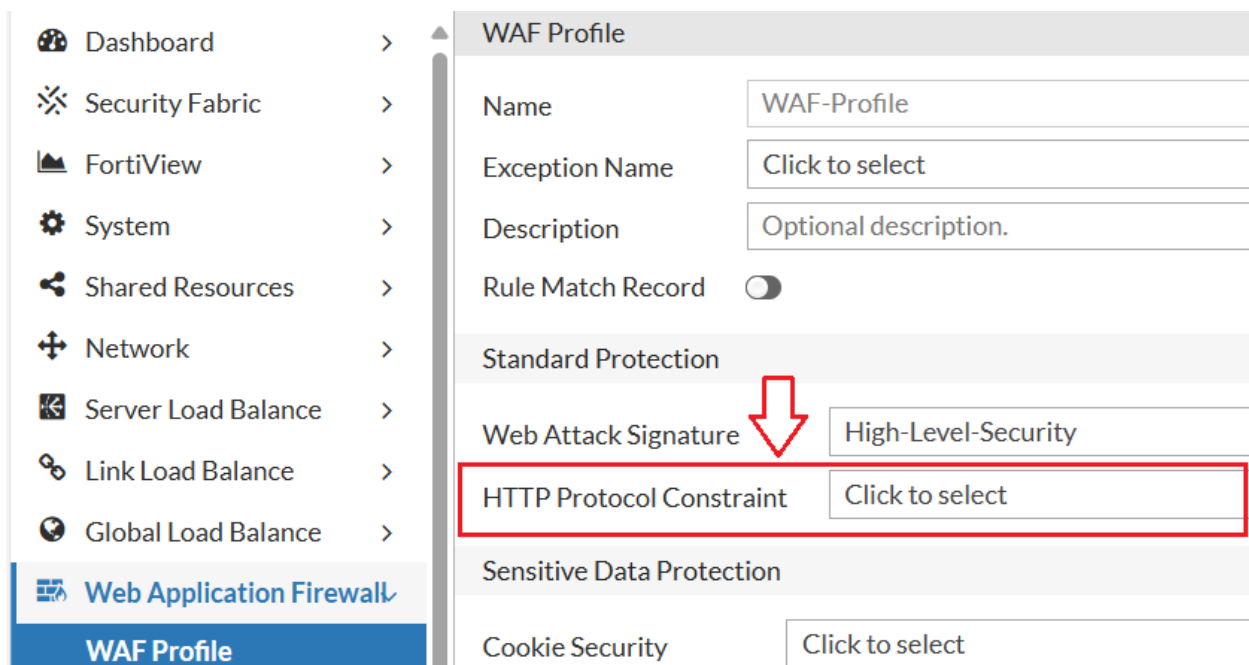
Signature ID: 1010010001
Message ID: 68493
Client IP: 100.0.1.3

Navigate to **Log & Report > Security Log** > choose from dropdown **WAF** to verify the logs related to HTTP Protocol Constraint.

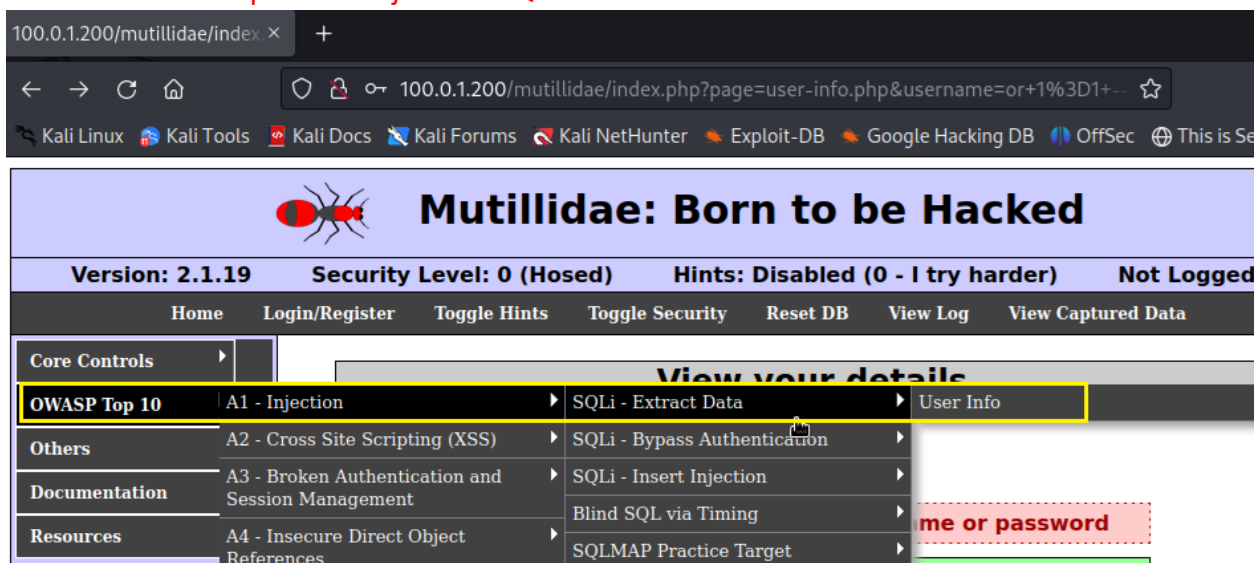
Dashboard	>	Download	Refresh	WAF	25/03/07 21:19:19 - 21:19:19
Security Fabric	>	Add Filter			
FortiView	>				
System	>				
Shared Resources	>				
Network	>				
Server Load Balance	>				
Link Load Balance	>				
Global Load Balance	>				
Web Application Firewall	>				
Network Security	>				
DoS Protection	>				
User Authentication	>				
Log & Report	>				
Traffic Log					
Security Log					

Date	Time	WAF Subcategory
2025-03-20	19:16:31	HTTP Protocol Constraint
2025-03-20	19:16:29	HTTP Protocol Constraint
2025-03-20	19:16:23	HTTP Protocol Constraint
2025-03-20	19:16:21	HTTP Protocol Constraint
2025-03-20	18:30:07	HTTP Protocol Constraint
2025-03-20	18:26:19	HTTP Protocol Constraint
2025-03-20	18:20:51	HTTP Protocol Constraint
2025-03-20	18:20:51	HTTP Protocol Constraint
2025-03-20	18:20:50	HTTP Protocol Constraint
2025-03-20	18:20:50	HTTP Protocol Constraint
2025-03-20	18:20:48	HTTP Protocol Constraint

Let's remove HTTP Protocol Constraint rule from our WAF-Profile. Click **Web Application Firewall > WAF Profile**. Double click to open WAF-Profile under Standard Protection section remove HTTP Protocol Constraint rule and click **Save**.



On the External Kali Linux, open Firefox browser and type <http://100.0.1.200> click on mutillida click on **OWASP Top 10>A1-Injection>SQLi-Extract Data>User info**



In the name and password section type below and click View Account Details:

' or 1=1 --

Security Level: 0 (Hosed) Hints: Disabled (0 - I try harder) Not Logged In	
login/Register	Toggle Hints Toggle Security Reset DB View Log View Captured Data

View your details

 **Back**

Authentication Error: Bad user name or password

Please enter username and password to view account details

Name

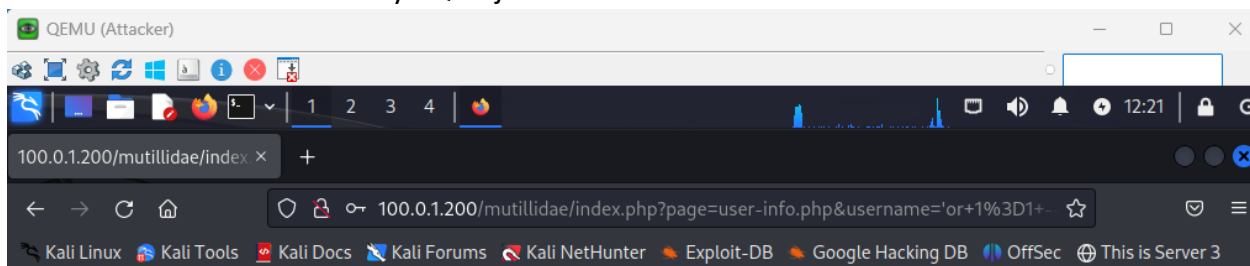
Password

[View Account Details](#)



Dont have an account? [Please register here](#)

The access has been denied by SQL Injection rule in WAF-Profile.



Access Denied

Signature ID: 1020000001
Message ID: 68514
Client IP: 100.0.1.3

Navigate to **Log & Report>Security Log >** choose from dropdown **WAF** to verify the logs related to SQL/XSS Inject Detection

Dashboard	>	Download	Refresh	WAF	25/03/07 21:19:19 - 25/03/20 19:2
Security Fabric	>	Add Filter			
FortiView	>				
System	>				
Shared Resources	>				
Network	>				
Server Load Balance	>				
Link Load Balance	>				
Global Load Balance	>				
Web Application Firewall	>				
Network Security	>				
DoS Protection	>				
User Authentication	>				
Log & Report	▼				
Traffic Log					
Security Log					

Date	Time	WAF Subcategory
2025-03-20	19:21:14	SQL/XSS Inject Detection
2025-03-20	19:19:28	SQL/XSS Inject Detection
2025-03-20	19:16:31	HTTP Protocol Constraint
2025-03-20	19:16:29	HTTP Protocol Constraint
2025-03-20	19:16:23	HTTP Protocol Constraint
2025-03-20	19:16:21	HTTP Protocol Constraint
2025-03-20	18:30:07	HTTP Protocol Constraint
2025-03-20	18:26:19	HTTP Protocol Constraint
2025-03-20	18:20:51	HTTP Protocol Constraint
2025-03-20	18:20:51	HTTP Protocol Constraint
2025-03-20	18:20:50	HTTP Protocol Constraint